

Policies and Permissions

1. Download a sample IAM policy JSON (for example, from AWS documentation), identify all users and their permissions, and list any permissions that are broader than necessary for typical user actions.

ANS

Permission	Access Granted	Is it Too Broad?	Reason
s3:*	Full control of all S3 buckets and objects	Yes	Most users only need to read or upload specific files, not delete or manage every bucket.
ec2:*	Full control of all EC2 instances	Yes	Typical users do not need to launch, terminate, or modify every EC2 instance.

❖ Permissions Broader Than Necessary

- s3:*
 - ec2:*
- These permissions violate the **Principle of Least Privilege** because they grant more access than most users require.

2. Edit the given IAM policy to implement least privilege access for a food delivery app scenario (e.g., only allow delivery agents to update order status, not delete orders), and save your revised policy as `optimized_policy.json`.

ANS

❖ Explanation

- Delivery agents can **view** order details.
 - Delivery agents can **update** order status.
 - They **cannot delete**, create, or modify other resources.
 - This follows the **Least Privilege** principle.
- FOR THIS YOU HAVE TO TYPE CODE ABOUT YOUR POLICY

3. Review an IAM policy that grants full S3 access to a group called 'AppUsers' and modify it so users can only read from a specific bucket named 'user-uploads', not write or delete files.
Hint: Use the 'Action' and 'Resource' fields to restrict permissions.

ANS

❖ Users can:

- View the bucket contents.
- Download files.

❖ Users cannot:

- Upload files.
- Delete files.
- Modify bucket settings.

➤ FOR THIS YOU HAVE TO TYPE CODE ABOUT YOUR POLICY

4. Write a checklist of 5 steps you would follow to regularly review IAM policies for a movie ticket booking app (like BookMyShow), including how you would identify unused permissions and revoke them.

ANS

Step	Description
1. Review Existing Permissions	Check every IAM user, group, and role to verify that only the required permissions are assigned.
2. Identify Unused Permissions	Use IAM Access Analyzer or AWS CloudTrail to find permissions that have not been used recently.
3. Apply Least Privilege	Remove unnecessary actions such as * permissions and replace them with only the required actions.
4. Remove Inactive Users	Disable or delete IAM users, roles, or groups that are no longer required.
5. Perform Regular Audits	Review IAM policies monthly or quarterly and update them whenever application requirements change.

5. Use ChatGPT or another AI tool to analyze a provided IAM policy snippet and suggest at least two improvements to enhance security following best practices.

Hint: Paste the policy into the AI tool and ask for recommendations based on least privilege and regular review.

ANS

❖ Improvement 1

- Replace:
 - Action: *
 - with only the required actions, such as:
 - s3:GetObject
 - dynamodb:GetItem
 - ec2:DescribeInstances
- This follows the **Least Privilege** principle and reduces unnecessary access.

❖ Improvement 2

- Replace:
 - Resource: *
 - with specific resource ARNs, for example:
 - arn:aws:s3:::user-uploads/*
- This limits access to only the required bucket instead of all AWS resources.